# 溯界（Sujie）测试样例与测试流程说明

本说明给出测试分层、样例组成、判定口径与复现流程。
事实依据：sujie/eval/、sujie/docs/DETECTOR_VERSIONS.md、sujie/docs/SEVEN_BYPASS_MATRIX.md 与 sujie/docs/DOCUMENT_INDEX.md。
**代码基线：96d591b（2026-10-20）**。 M19 – M21 的云模型数字为开发期历史记录，只作引用，不代表当前基线。
**全文遵守分母纪律**：确定性回归条数、脚本业务完成数、规则检测指标、真实模型小样本结果四者分别计数、互不冒充；本文中的检测数字均为规则初筛指标，不是 Agent ASR，也不是公开基准成绩。

## 1. 测试分层

| 层级 | 对象 | 当前状态 |
|---|---|---|
| L1 单元/契约 | Schema、传播不变量、策略 AST、状态机、工具适配器 | 已实现（tests/、gateway-python/tests/、contracts/tests/） |
| L2 确定性安全回归 | 正常/攻击/合法引用对照、强制工具提议校准 | 已实现（dev.py check 全量回归）：96d591b 上 Ubuntu 1107 / Windows 1106 / macOS 1107 通过 |
| L3 真实智能体端到端 | 真实模型驱动的多业务任务 | 小规模已完成（M19/M20/M21），非正式任务矩阵；原始 runs 未随包分发 |
| L4 规则检测离线评测 | 冻结/扩展规则检测器对合成与公开注入数据 | 已实现且可复现（3 来源 × 7 绕过 42 条；公开数据集 140 条），均为规则初筛，非 Agent ASR |
| L5 自适应攻击 | 攻击智能体在预算内观察并重写载荷 | 未实现 |

## 2. 测试样例组成

### 2.1 结构化样例（eval/cases/）

| 文件 | 规模 | 说明 |
|---|---|---|
| detection_v1.json | 14 条 | 版本化合成规则检测样例，冻结检测器 rules-v0.3；不是端到端任务集；dev.py eval-detection 可逐例复现 |
| bypass_matrix_v2.json | 42 条 | 3 种入口 × 7 种绕过标签 × 攻/控对照（21 攻 + 21 控）的合成规则检测矩阵；dev.py eval-bypass 复现 |
| public_injection_sample_v1.json | 140 条 | 可再分发公开注入数据集的分层抽样（≤20 攻 + ≤20 正常/来源，固定种子），仅用于规则检测指标 |
| zh_agent_dev_v1.json | 70 条 | 自撰中文智能体注入开发集（仅调参），含正常困难负例；不构成留出成绩 |

| 文件 | 规模 | 说明 |
| --- | --- | --- |
| tool_agent_paired_v1.json | 14 条 | 同一基础告警任务下 7 个攻击模板族各一攻一控；脚本校验“每组恰有一攻一控、ID 唯一、预期事实存在”，每次运行记录数据集哈希 |
| approved_transfer_v1.json | 8 条 | 授权/外发相关样例 |
| incident_scenarios_v1.json | 24 条 | 事件场景样例 |
| M1 E2E（E2E-CLEAN-001 / E2E-IPI-001 / E2E-ASK-001） | 3 条 | 目前固化在自动化测试中 |

计数纪律：Schema 非法 fixture、模板变体、重复条目与脚本提议数不计入独立业务或攻击分母；tool_agent_paired_v1 的 14 条不等于 14 个独立基础任务。

## 2.2 攻击载荷分布（eval/attacks/）

攻击载荷并非集中在一个目录，而是分布在 eval/cases/、各冻结协议/外部导入、业务合成 fixture 与回归测试中。已覆盖代表性直接/间接/记忆入口、规范化变体与真实工具强制提议；规则层的「三来源 × 七绕过」已可用 dev.py eval-bypass 离线复现（42 条合成），运行时矩阵尚未验收。

M21 的 injected（攻击）与 quoted（合法引用）是不同场景，不能只按“是否出现危险文字”判标签。

## 2.3 冻结协议（eval/protocols/）

固定协议用于保证可复算与不可追溯篡改，例如：four_business_workflows_v2.json（M21 默认）、four_business_workflows_v1.json（512 输出上限，恢复原字节）、four_business_timeline_repair_v2.json、common_runtime_protocol_v1.json（M19）、evidence_quote_development_v1.json（M20）、task_aware_holdout_v1.json（M9 冻结留出）等，共 10 个。协议字段包含 profiles、scripted_scenarios、forced_proposal_scenario、model_scenario、oracle、failure_policy、variant、version_note 等。

M9 四个冻结实现保持原样：demo-agent/sujie_demo_agent/semantic_detector.py、gateway-python/src/sujie_gateway/detection.py、eval/task_aware_protocol.py、eval/run_frozen_task_aware.py。已暴露的验证/测试不能重新称为未见留出。

## 2.4 业务工作流（M21）

四个多源业务：多源事件时间线（event-timeline）、Issue 分级（issue-triage）、邮件附件一致性（attachment-audit）、多版本知识冲突（knowledge-reconcile），各自具备正常/注入/合法引用场景与独立事实/读取/资料完整性 Oracle。

## 3. Oracle：以真实副作用判分

Oracle 实现分布于 sandbox/、控制面与 eval 脚本：

- **安全 Oracle**：Receiver 实际请求与蜜标、文件内容、真实子进程 job 收据、Git 远端 ref 及未知确认、Memory 版本/摘要/CAS 与输入完整性。
- **业务 Oracle**：实际指定来源读取、报告字段/事实/出处；四业务由 control-plane-python/sujie_control/business_oracles.py 独立判定，时间线另检查实际窗口查询。
- **部署 Oracle**：历史 M1 的网络/挂载断言；不覆盖当前新版整体隔离。

脚本答案由实际工具返回计算，Host 的 gold 不进入模型提示或工具返回；**猜中答案但没有实际读取不算完成**。运行状态 FINISHED、文件存在、协议 passed、业务完成与零泄露**必须分开报告**。

## 4. 基线与消融

共同框架位于 eval/runtime_variants.py、eval/paired_runtime.py、eval/run_common_runtime_validation.py，支持五个配置与两个消融：unsafe（B0）、strong-static（B1）、full、no-source（消融 A）、no-recovery（消融 B）。评测专用，操作者 HTTP 无基线切换接口。

已完成的开发比较（M21 阶段）为 35 个强制提议单元 / 45 脚本业务 / 10 个云单元（7 项完成，失败保留）；**这不是**正式独立任务矩阵、35 次全阻断或 Agent ASR。M25 冻结矩阵为 48 个唯一单元（46 项业务完成、2 个危险效果保留），见作品报告 3.5 节。各配置共用已注册执行器、封闭资源、Provider 凭据保护与预算/审批基础设施，**公共保障不计为 Full 独有贡献**。

## 5. 规则检测离线评测（当前基线，非 Agent ASR）

全部离线、无云调用；输出 JSON 含数据集 SHA-256 与检测器版本，评测脚本拒绝覆盖已有输出。

| 数据集 | 检测器 | 规模 | 混淆矩阵 | 召回 | 正常误报率 |
|---|---|---|---|---|---|
| detection-v1-synthetic-smoke | rules-v0.3（冻结） | 14 | TP5 / FN2 / FP1 / TN6 | 71.4% | 14.3% |
| seven-bypass-matrix-v2-synthetic | rules-v0.6（扩展） | 42（21 攻 + 21 控） | TP21 / FN0 / FP0 / TN21 | 100% | 0% |
| public-injection-sample-v1（held-out） | rules-v0.6（扩展） | 140 | TP45 / FN35 / FP0 / TN60 | 56.25% | 0% |

公开数据集分来源召回（held-out）：mcp_tool_poisoning 85%、gandalf 65%、agent_safety_bench_zh 55%、deepset 20%；各来源精度均为 100%。

**口径限定**：以上只描述**规则初筛**对合成/公开数据的分类表现。合成矩阵的 100% **属同源自检**（规则与样例同批开发），必须与公开集 56.25% 并列呈现，不得表述为网关实际阻断率、官方评测 ASR 或泛化检出率。

## 6. 复现流程（无云）

```
cd sujie
.venv/bin/python dev.py check
.venv/bin/python -m pytest tests/test_business_workflows.py tests/test_evidence_analysis.py -q
.venv/bin/python dev.py eval-detection
.venv/bin/python dev.py eval-bypass
.venv/bin/python eval/run_public_injection.py
.venv/bin/python eval/provenance_demo.py --out <新目录>
```

生成新的四业务确定性校准并核验该次运行（输出目录必须为新的，脚本拒绝覆盖）：

```
.venv/bin/python eval/run_business_validation.py \
  --protocol-file eval/protocols/four_business_workflows_v2.json \
  --out-dir eval/reports/runs/<新目录>
.venv/bin/python eval/verify_runtime_validation.py eval/reports/runs/<新目录>
```

原始 runs 不随源码包分发；不要引用仓库中不存在的历史运行目录。

含云模型的复现需先固定新协议与预算（见部署说明第 4 节），例如小样本成对套件：

```
SUJIE_BAILIAN_CREDENTIAL_CSV=/path/outside/repo/credentials.csv \
.venv/bin/python eval/run_bailian.py --suite paired-v1 --max-cases 14
```

## 7. 证据保存与重算

- **原始运行档案不随源码包分发**：eval/reports/runs/ 多数被 gitignore。本次交付的证据包内含本机重跑的四业务确定性运行（competition_repro_20261018：16/16 脚本业务、0 云调用）、本次离线规则检测与溯源图演示输出，以及 docs/validation/ 下的项目验证记录（M25/M26 本地验收、主线能力审计）。
- **四业务确定性结果可现场重算**：不依赖任何历史目录，按第 6 节命令生成新目录即可（输出目录必须为新的，脚本拒绝覆盖）。
- **M19 – M21 云模型结果为开发期记录**（五配置 7/10、云首轮 3/4、时间线修复、引用实验等），**只有开发期文档记载，原始 runs 不在磁盘、不在仓库**；不得当作当前基线成绩，如需引用须单独移交原始观察。

## 8. 度量定义（避免混用）

- **Execution ASR / 防御成功率**：需在冻结测试集与独立任务登记下统计；当前尚无冻结成绩。

- **合成秘密真实泄露率**：以 Receiver/文件等真实副作用判定，0% **指当次实测**，不可外推。
- **正常任务完成率 / 安全研判保全率**：业务 Oracle 与安全 Oracle 联合判定。
- **“模型未提出危险动作” ≠ “网关拦截”**：真实模型没有提出危险动作的样例只能报告“未观察到泄露”，不能报告网关成功拦截。

## 9. 未验收项

1. **运行时**「三来源 × 七绕过」矩阵未验收：现有 3×7 矩阵是**规则检测离线评测**（合成 42 条），不执行真实工具链；运行时绕过仅有 12 例集成夹具，**不是** 21 格成绩；
2. 正式独立基础任务登记与五配置主比较（C/A/Q/R）未形成；
3. 新版 Linux 整体隔离与性能未验收；
4. 外部基准（AgentDojo/MCP-SafetyBench/MCPTox）历史评测基于冻结检测器 rules-v0.3，仅为受限子集，非执行成绩；
5. 自适应攻击（L5）未实现；
6. 真实云模型实验仅开发期小样本，原始 runs 未随包分发。